

ASSESSMENT - 3

NIVEDHITHA G

192521231

ITA1412

1) Nmap Scan Without Permission - Ethical and Legal Analysis.

The student's action is unethical and illegal because network scanning was performed without the company's permission.

Even though no data was stolen or systems were damaged, scanning another organization's network without authorization violates ethical hacking principles.

Under the (IT) Act, 2008, the following sections apply:

- ⇒ Section 43: Unauthorized access or interference with computer systems can result for damages.
- ⇒ Section 66: If the unauthorized access is done dishonestly, it becomes a criminal offence punishable with imprisonment or fine.

Possible legal consequences:

- ⇒ Legal notice from the company.
- ⇒ Payment of compensation for damages.
- ⇒ Criminal prosecution if malicious intent proven.
- ⇒ Damage to the student's professional reputation.

Correct procedure:

Before conducting any security assessment, the student should:

- ⇒ Obtain written permission from the company.
- ⇒ Define the scope of testing.
- ⇒ Sign a legal authorization or Non-Disclosure Agreement (NDA).
- ⇒ Perform the scan only within the approved limits and submit the findings responsibly.

2) SQL Injection Vulnerability Published Publicly.

The researcher's action is ethically irresponsible because the vulnerability details and proof-of-concept code were published before informing the organization. This allowed attackers to exploit the weakness before it could be fixed.

Under the Act, 2008, exploiting such vulnerabilities or enabling cybercriminals to misuse them may result in legal action if it leads to unauthorized access or data compromise.

Responsible Vulnerability Disclosure (RVD):

- ⇒ Report the vulnerability privately to the organization.
- ⇒ Give sufficient time for the company to fix the issue.
- ⇒ Avoid publishing exploit code until a security patch is released.
- ⇒ Coordinate with the organization before public disclosure.

Risks of premature disclosure:

- ⇒ Customer data theft.
- ⇒ Financial loss.
- ⇒ Reputation damage to company.
- ⇒ Increased cyberattacks.

3) Phishing Attack on Employee

This is a Phishing Attack, a form of social engineering where attackers trick users into revealing confidential information through fake emails.

The attackers use the employee's login credentials to gain unauthorized access to company data.

Application IT Act Sections:

- ⇒ Section 43 → Unauthorized access causing damage.
- ⇒ Section 66 → Computer-related offences.
- ⇒ Section 66C → Identify theft.
- ⇒ Section 66D → Cheating by personation using CP resources.

Responsibilities:

Organization:

- ⇒ Provide cybersecurity awareness training.
- ⇒ Enable Multi-factor Authentication.
- ⇒ Use email filtering and spam protection.

Employee:

- ⇒ Verify email authenticity.
- ⇒ Avoid clicking suspicious links.
- ⇒ Follow company security policies.

A) Student Exploits Bank Vulnerability Before Reporting

The student's action is not ethical or lawful because customer information was accessed without authorization, even though the intention was to demonstrate the vulnerability.

Ethical hacking requires prior permission from the organization.

Unauthorized access is considered hacking under law.

Applicable IT Act Sections:

- ⇒ Section 43: Unauthorized access and data retrieval.
- ⇒ Section 66: Computer-related offences involving dishonest or fraudulent access.
- ⇒ Section 72: Breach of confidentiality and privacy if customer information is disclosed.

Proper reporting process;

- ⇒ Do not exploit or download customer data.
- ⇒ Maintain confidentiality until the issue is fixed.
- ⇒ Follow responsible vulnerability disclosure practices.